

PCI DSS v4.0.1 in 2026: What's Actually Mandatory Now

The transition period is over. Here is what every fintech and payment processor needs to know today.

A Digital Asset Defenders Deep-Dive Guide | Updated August 2026

Introduction

PCI DSS v4.0 was published in March 2022 as the first major revision to the Payment Card Industry Data Security Standard in over a decade, introducing 64 new or revised requirements. To give organisations time to adapt, the PCI Security Standards Council (PCI SSC) split those requirements into two tiers: 13 took effect immediately, and 51 were designated “future-dated” — treated as best practice until a hard deadline. That deadline, 31 March 2025, has now passed. There is no grace period, and there is no remaining ambiguity: every PCI DSS assessment conducted from that date forward scores all 64 requirements as fully in scope.

A limited revision, PCI DSS v4.0.1, was published on 11 June 2024. It corrected formatting and clarified intent in places, but added no new requirements and did not move the 31 March 2025 cutover. PCI DSS v4.0 itself retired on 31 December 2024 (v3.2.1 had already retired on 31 March 2024), which means v4.0.1 is now the only active version of the standard. If your last assessment predates March 2025, or if you treated the future-dated controls as optional, your next assessment will not give you that latitude.

Timeline: How We Got Here

Date	Milestone
March 2022	PCI DSS v4.0 published, introducing 64 new/revised requirements
31 March 2024	PCI DSS v3.2.1 retires
11 June 2024	PCI DSS v4.0.1 published (limited revision, clarifications only)
31 December 2024	PCI DSS v4.0 retires; v4.0.1 becomes the sole active version
31 March 2025	All 51 future-dated requirements become mandatory, with no grace period
June–July 2026	PCI SSC runs a further RFC on the next standard, with a focus on AI and emerging technology

What's Actually Mandatory in a 2026 Assessment

The following controls were “best practice” as recently as early 2025. They are not anymore. These are the requirements Digital Asset Defenders sees fail most often in gap assessments today:

- **Requirement 8.3.1 — Multi-factor authentication for all access to the cardholder data environment.** Previously MFA was required only for administrative and remote access; it now applies to all user access to system components in the CDE.
- **Requirement 6.4.2 — Web Application Firewall (or equivalent).** All external-facing web applications handling cardholder data must be protected by a WAF or an equivalent dynamic application security solution.
- **Requirement 6.4.3 — Payment page script management.** Organisations must maintain an inventory of every script that executes on a payment page and justify why each one is authorised to run there.
- **Requirement 11.6.1 — Payment page tamper detection.** A mechanism must detect and alert on unauthorised modifications to payment-page HTTP headers and script content (the control most directly aimed at web-skimming/Magecart-style attacks).
- **Segmentation testing** — service providers must perform segmentation testing at least twice per year for multi-tenant environments, not annually.
- **Encryption of stored account data** — full-disk encryption alone is no longer an acceptable control for protecting stored cardholder data; more granular, application- or field-level encryption is expected.
- **Vulnerability management** — remediation now covers vulnerabilities of all severities, not only high and critical findings.
- **A documented, organisation-specific penetration testing methodology** — aligned to an industry-accepted approach such as OWASP Top 10, NIST SP 800-115, or PTES, and consistently applied.
- **Software Bill of Materials (SBOM)** — for custom software, organisations must obtain and maintain an SBOM documenting all third-party and open-source components.
- **Requirement 5.4.1 — Phishing-aware training.** Security awareness training must now include methods for confirming sender identity, not just generic phishing recognition.
- **Requirement 12 scope validation** — PCI DSS scope must be formally re-validated annually for merchants and every six months for Third-Party Service Providers (TPSPs).

Where 2026 Assessments Actually Fail

In practice, the e-commerce script requirements (6.4.3 and 11.6.1) are the most common source of assessment failures right now — and they typically fail on governance, not technology. Most payment gateways already support the required tamper-detection capability; what's usually missing is the documented inventory, the change-approval process for adding a new script, and evidence that someone actually reviews it. The second most common failure mode is treating the annual PCI cycle as a point-in-time event rather than the continuous, business-as-usual programme v4.0.1 explicitly requires: organisations that pass an assessment and then let controls lapse until the next cycle are increasingly caught out.

What Comes Next

A successor standard is in early development but is not imminent. According to the PCI SSC's 2025 Annual Report (published January 2026), a second Request for Comments cycle for a future version closed in December 2025, and a further RFC ran from 3 June to 20 July 2026, specifically asking stakeholders how the standard should evolve to address AI and future payment technology. No release date has been announced, and the Council's own history suggests a multi-year runway before any new major version becomes mandatory — but organisations should expect the next revision to formalise AI-related risks (fraud models, AI-assisted attacks, and AI-generated code in payment applications) given the direction of that consultation.

The Kenyan Context: PCI DSS Meets the DPA and CBK Guidelines

For Kenyan fintechs and payment service providers, PCI DSS compliance rarely stands alone. The Central Bank of Kenya's Guidelines on Cybersecurity for Payment Service Providers (2019) explicitly ties payments-data handling to the Data Protection Act 2019, and CBK's 2024 harmonisation effort is pulling PSP-specific cybersecurity requirements, the Commercial Banks Cybersecurity Guidelines, and the Computer Misuse and Cybercrimes (Critical Information Infrastructure and Cybersecurity) Regulations 2024 into one converging compliance obligation. In practice, this means a PCI DSS gap assessment for a Kenyan payment processor should be scoped alongside DPA breach-notification timelines and CBK incident-reporting obligations from the outset, rather than treated as three separate exercises.

Compliance Roadmap

- 1 Run a full gap analysis against PCI DSS v4.0.1, including every formerly future-dated requirement.
- 2 Prioritise the highest-effort controls first: payment-page integrity (6.4.3 / 11.6.1), WAF deployment, expanded MFA coverage, and authenticated vulnerability scanning.
- 3 Build a documented, repeatable penetration testing methodology rather than an ad hoc annual test.
- 4 Generate and maintain an SBOM for any custom payment-facing software.
- 5 Move from an annual compliance event to a continuous evidence-collection habit — logs, change records, and scan results that are already organised before your assessor asks for them.
- 6 Engage your QSA (Qualified Security Assessor) early if your validation level requires one, so scope is agreed well before the assessment window opens.

How Digital Asset Defenders Can Help

- PCI DSS v4.0.1 gap assessments, including the formerly future-dated requirements
- Scope definition and validation (annual for merchants, semi-annual for TPSPs)
- Penetration testing aligned to OWASP, NIST SP 800-115, or PTES
- Segmentation testing for multi-tenant service provider environments
- WAF selection, deployment, and tuning

- SBOM generation and software supply chain documentation
- Policy development and staff training

PCI DSS v4.0.1 has moved payment security from a checkbox exercise to a continuous, risk-based discipline. With the transition deadline behind us and a further evolution already being scoped by the Council, the organisations in the strongest position are the ones treating this as an ongoing programme rather than a once-a-year scramble. Contact Digital Asset Defenders for a gap assessment against the full current standard.

Sources & Further Reading

- PCI Security Standards Council — pcisecuritystandards.org
- PCI SSC Blog, “Now is the Time for Organizations to Adopt the Future-Dated Requirements of PCI DSS v4.x”
- Compyl, “PCI DSS 4.0.1 Compliance Guide: Every Requirement That’s Now Mandatory”
- Cybernion, “PCI DSS 4.0.1 Changes”, July 2026
- SICHERTEN, “PCI DSS v4.0.1 in 2026: every requirement is now mandatory”
- SecurityWall, “PCI DSS v4.0 & v4.0.1: Everything That Changed and What You Must Do by 2026”
- Xcobeau, “Kenya Cloud & Data Protection Compliance 2026”